CLAUDE CERTIFIED ARCHITECT — PROFESSIONAL

Objective 29: Ensure Regulatory Compliance

Exam objective: Ensure regulatory compliance across frameworks such as GDPR, HIPAA, and FedRAMP, covering data privacy and protection, data retention, data residency, access controls, auditability, deployment-specific compliance requirements, and how the chosen deployment platform affects compliance obligations.

Q1 **A European retail company wants to use Claude to analyze customer support transcripts that include EU residents' personal data. Legal counsel asks the architecture team how GDPR's "right to erasure" should be technically supported. What is the correct architectural approach?**

A Rely on Claude to simply "forget" the data after the conversation ends

B **Build a data pipeline that tracks where customer personal data is stored (including any logs, embeddings, or fine-tuning datasets) so that a deletion request can be deterministically propagated and verified across all storage locations**

C Tell customers that erasure is technically impossible with AI systems

D Only delete the data from the primary production database, ignoring backups and logs

CORRECT ANSWER **B**

WHY GDPR erasure rights require a deterministic, auditable data pipeline capable of locating and deleting personal data across all systems where it persists (including logs and derived stores), not reliance on the model's ephemeral context. A is not how data persistence works, C is an invalid excuse, and D leaves data remnants that violate the right.

Q2 **A U.S. hospital system wants to use Claude to help draft patient discharge summaries. Which deployment consideration is most critical to satisfy HIPAA requirements?**

A Using the most capable Claude model available, regardless of vendor agreements

B **Ensuring a signed Business Associate Agreement (BAA) is in place with the model provider/platform, and that protected health information (PHI) is only processed through infrastructure covered by that BAA with appropriate access controls and audit logging**

C Simply including a disclaimer in the system prompt that the tool is "HIPAA compliant"

D Avoiding any logging of PHI processing to reduce liability

CORRECT ANSWER B

WHY HIPAA compliance for a vendor handling PHI fundamentally requires a Business Associate Agreement plus technical safeguards (access controls, encryption, audit logs) on covered infrastructure — a legal and architectural requirement, not something a prompt disclaimer can satisfy. A and C are incorrect, and D actually undermines the auditability HIPAA requires.

Q3 **A federal government agency wants to deploy a Claude-based assistant for internal use. Which factor most directly determines whether this deployment can satisfy FedRAMP requirements?**

A Whether the system prompt mentions "FedRAMP compliant"

B **Whether the underlying cloud/model deployment environment has an active FedRAMP authorization (at the appropriate impact level) covering the specific services being used**

C Whether the agency uses Claude for unclassified tasks only, which is assumed to waive all requirements

D Whether the agency's IT staff have security clearances

CORRECT ANSWER B

WHY FedRAMP compliance is a property of the authorized cloud service offering/deployment environment at a given impact level (Low/Moderate/High), not something conferred by a disclaimer or prompt text — the specific services in use must be within the FedRAMP authorization boundary. A, C, and D do not establish compliance.

Q4 **A multinational bank wants its Claude-powered fraud-analysis tool to comply with data residency requirements that mandate EU customer data never leave EU-based infrastructure. What is the most appropriate architectural solution?**

A Process all data in a single global data center and rely on contractual promises alone

B **Deploy the model access and all associated data storage/processing pipelines within an EU region specifically, verifying that inference requests, logs, and any caching layers also remain in-region**

C Encrypt the data before sending it anywhere, since encryption satisfies residency requirements regardless of physical location

D Only worry about residency for data at rest, ignoring data in transit or in processing

CORRECT ANSWER **B**

WHY True data residency compliance requires verifying the entire processing path — inference, logging, caching — stays within the required geographic/regulatory boundary, not just where data is stored at rest. A relies on insufficient contractual-only assurances, C conflates encryption with residency (they are different concerns), and D ignores in-transit/in-processing exposure.

Q5 **A healthcare SaaS company must demonstrate to auditors exactly which employees accessed a given patient's AI-generated summary and when. What capability must be built into the system to satisfy this?**

A A general system prompt stating that privacy is important

B **Comprehensive, tamper-evident access logging and auditability covering who accessed what AI-generated content and when, retained for the required compliance period**

C Deleting access logs after 24 hours to minimize data footprint

D Trusting that only authorized staff would ever use the system

CORRECT ANSWER **B**

WHY Auditability requires systematic, durable access logs capable of answering "who accessed what, when" — a core HIPAA/compliance requirement. A is not a technical control, C would destroy the very evidence needed for an audit, and D is not a verifiable control.

Q6 **An insurance company operating in multiple U.S. states and the EU asks the architecture team to design data retention policies for AI-generated claim assessments. What is the best approach?**

A Keep all data forever "just in case" it's needed for future disputes

B **Define retention periods per the strictest applicable regulatory and contractual requirement for each jurisdiction and data type, and implement automated deletion/archival workflows enforcing those periods**

C Use a single global retention period of 30 days for all data regardless of jurisdiction

D Let individual employees decide how long to keep data on their own devices

CORRECT ANSWER **B**

WHY Multi-jurisdictional retention compliance requires mapping requirements per data type/region and enforcing them via automated, deterministic workflows, since requirements often differ (e.g., insurance record retention laws vs. GDPR minimization principles). A violates data minimization principles, C ignores jurisdictional variance, and D creates uncontrolled, unauditable retention.

Q7 **A legal services company wants to use Claude to review contracts containing client-privileged information. Which access control principle is most important to implement for regulatory and ethical compliance?**

A All employees in the firm should have access to all client documents for convenience

B **Role-based access control ensuring that only attorneys and staff actively assigned to a given client matter can access that matter's documents and AI-generated analysis**

C Access controls are unnecessary since Claude itself keeps information confidential

D Only the firm's IT administrator needs access controls; other employees can bypass them if needed

CORRECT ANSWER B

WHY Enforcing matter-based, role-based access control at the system/data layer is essential to preserving privilege and client confidentiality — a backend authorization concern, not something the model can enforce on its own. A and D violate least-privilege and confidentiality obligations, and C incorrectly assumes model-level enforcement is sufficient.

Q8 **A telecom company deploying Claude via a cloud provider's managed AI service asks: "If our cloud provider's service terms allow them to use our prompts for their own model training by default, what compliance risk does this create?" What is the correct assessment?**

A. No risk — all cloud AI services anonymize data by default

B. **A potential data privacy/confidentiality risk, since customer or regulated data could be used in ways inconsistent with privacy regulations or contractual obligations unless the service is configured/contracted (e.g., via enterprise/zero-retention terms) to prevent such use**

C. This only matters for GDPR, not for any US regulations

D. This is purely a legal issue with no architectural dimension

CORRECT ANSWER B

WHY Default data-usage terms of a given deployment platform directly affect compliance obligations — architects must verify and configure (via enterprise agreements, zero-data-retention options, etc.) that regulated data isn't used in ways that violate privacy law or client contracts. A is a false assumption, C understates applicability (US laws and contracts matter too), and D ignores that platform configuration is an architectural decision.

Q9 A government contractor must demonstrate "auditability" for an AI system used in procurement decisions, as part of a compliance review. Besides access logs, what additional capability most strengthens auditability for AI-assisted decisions?

A The ability to reproduce or explain why the AI generated a particular recommendation, including the inputs, retrieved context, and version of the model/prompt used at decision time

B A marketing brochure describing the AI vendor's general safety philosophy

C Deleting model version history to simplify the environment

D Avoiding documentation of prompt changes over time

CORRECT ANSWER **A**

WHY Full auditability for AI-assisted decisions requires traceability — knowing exactly what inputs, context, and model/prompt version produced a given output — so decisions can be reconstructed and defended later. B is irrelevant, and C and D actively destroy the information needed for a defensible audit trail.

Q10 **A hospital's compliance officer asks why the organization cannot simply use a free, consumer-facing version of a Claude-based chatbot for internal clinical workflows. What is the most accurate explanation?**

A Consumer products are technically identical to enterprise offerings, so there's no issue

B **Consumer-facing products typically lack the contractual protections (e.g., BAA), data handling guarantees, and administrative/audit controls required for processing PHI under HIPAA, whereas enterprise/API deployments are built to support these obligations**

C Clinical workflows are not subject to HIPAA if the chatbot is "just for drafting"

D The only difference is cost, so a free product is equally acceptable if the hospital saves money

CORRECT ANSWER **B**

WHY Regulatory suitability often depends on the specific deployment tier/platform and its contractual and technical guarantees (BAAs, data retention controls, admin/audit tooling) — consumer products typically don't offer these, making them unsuitable for regulated PHI workflows. A, C, and D are incorrect or dangerously dismissive of HIPAA applicability.

Q11 **An insurance company operating under both GDPR and various U.S. state privacy laws wants to minimize compliance risk from its Claude integration. Which design principle best supports this across both regimes?**

A Collect and retain as much customer data as possible in every prompt to maximize context and usefulness

B **Apply data minimization — only include the specific fields actually necessary for the task in any prompt or tool call, and avoid retaining unnecessary personal data longer than required**

C Only comply with GDPR since U.S. state laws are not relevant to insurance

D Assume that anonymization is unnecessary since the data is only used internally

CORRECT ANSWER B

WHY Data minimization is a convergent principle across GDPR, CCPA, and most U.S. state privacy laws, and directly reduces both compliance exposure and breach impact. A directly increases risk, C is factually wrong (many U.S. state laws apply to insurance), and D ignores applicable requirements regardless of internal-only use.

Q12 **A manufacturing company's AI governance committee wants to document which specific compliance obligations apply to its new Claude-based quality-control assistant before launch. What is the best first step?**

A Skip documentation and rely on the vendor's general compliance certifications as sufficient for all use cases

B **Conduct a use-case-specific compliance assessment identifying applicable regulations (e.g., industry-specific, regional, data-type-specific) based on the actual data processed, deployment platform, and jurisdictions involved**

C Assume no regulations apply since manufacturing is not typically a regulated industry

D Wait until after launch to see if regulators raise concerns

CORRECT ANSWER **B**

WHY Compliance obligations vary by actual data processed, deployment architecture, and jurisdiction — a use-case-specific assessment conducted before launch is the correct approach, since no single vendor certification covers every possible deployment scenario. A, C, and D all introduce significant, avoidable compliance risk.

Q13 **A SaaS company processes data for customers in both the EU and the US through a single Claude integration. A customer asks for proof that their data remains segregated from other customers' data and is handled per their specific contractual data processing agreement (DPA). What architectural capability directly supports this requirement?**

A. A shared, undifferentiated data store with no per-tenant tagging

B. Multi-tenant data architecture with strict logical (or physical) tenant isolation, tagging of data by jurisdiction/DPA terms, and the ability to apply customer-specific handling rules (e.g., retention, residency) per tenant

C. A single global policy applied uniformly to all customers regardless of their contracts

D. Informing the customer that per-tenant customization is not technically feasible

CORRECT ANSWER B

WHY Supporting differentiated contractual/regulatory obligations per customer requires tenant-aware architecture that can enforce distinct data handling rules (residency, retention, isolation) per DPA — a deterministic, backend design requirement. A, C, and D fail to meet customer-specific compliance commitments.

Q14 **A retail company wants to confirm whether its chosen deployment option (direct API vs. a specific cloud marketplace offering vs. an on-premises/VPC deployment) affects its compliance posture. What is the correct understanding?**

A All deployment options are functionally identical for compliance purposes

B **Different deployment options can carry different data handling guarantees, residency options, certifications (e.g., FedRAMP, SOC 2), and contractual terms, so the choice of deployment platform directly shapes which compliance obligations can be met**

C Compliance is solely determined by the model's training data, not by deployment choice

D On-premises deployment always eliminates all compliance obligations

CORRECT ANSWER **B**

WHY The deployment platform/channel chosen materially affects what compliance guarantees are available (certifications, residency controls, contractual terms), making this a key architectural decision point rather than an afterthought. A, C, and D misunderstand how compliance obligations attach to specific deployment choices.

Q15 **A government healthcare agency needs both HIPAA and FedRAMP considerations addressed for a single Claude-based citizen-services application handling health benefit inquiries. What is the best architectural approach?**

A Treat HIPAA and FedRAMP as mutually exclusive and pick only one to satisfy

B **Design the deployment to simultaneously meet both frameworks' requirements — using a FedRAMP-authorized environment at the appropriate impact level that also supports a BAA and the technical safeguards HIPAA requires — since the application must satisfy whichever frameworks legally apply to it**

C Assume federal deployments are automatically exempt from HIPAA

D Apply FedRAMP controls only to the frontend UI, leaving backend data processing unaddressed

CORRECT ANSWER B

WHY Overlapping regulatory frameworks are common in government healthcare contexts, and the architecture must be designed to satisfy all applicable requirements concurrently (authorized environment, BAA, technical safeguards), not choose one over another. A, C, and D reflect fundamental misunderstandings of how multiple compliance frameworks can apply simultaneously.

Q16 **An enterprise customer enables an organization-wide Zero Data Retention (ZDR) arrangement with its model provider and assumes this blanket setting guarantees that prompts and outputs are never stored at rest no matter which product feature is used, including batch processing, file uploads, and agent/code-execution features. A compliance review challenges this assumption. What is the correct understanding?**

A ZDR is a single universal switch that automatically covers every feature and API the provider offers once enabled

B **ZDR coverage must be verified feature-by-feature, since certain features (such as batch-processing APIs, file-upload/storage APIs, agent/skill features, code execution, and certain connector or managed-agent capabilities) are commonly excluded from a ZDR arrangement even when it is enabled at the organization level**

C ZDR only applies to HIPAA-regulated customers and is irrelevant to other compliance regimes

D Enabling ZDR eliminates the need for any other compliance control, such as access logging or retention policies

CORRECT ANSWER **B**

WHY Zero Data Retention arrangements are typically scoped to specific products/APIs, and an architecture team must confirm which specific features are actually covered rather than assuming an organization-level toggle blankets every feature, since using an excluded feature silently steps outside the arrangement for that data. A, C, and D all overstate what a single ZDR setting guarantees.

Q17 **A healthcare company enables HIPAA readiness (with a signed Business Associate Agreement) in its model provider's console for its patient-intake assistant. Several months later, a separate team wants to reuse the same provider account to run an unrelated autonomous coding/DevOps agent feature, and assumes the existing BAA automatically extends PHI protection to that new feature as well. What should the architecture team verify before approving this?**

A Nothing — once HIPAA readiness is enabled for an account, every feature offered by that account is automatically covered

B **Whether the specific new feature (e.g., an autonomous coding/agent capability) is actually included in the HIPAA-covered feature set, since HIPAA readiness is typically permanent for the account but does not necessarily extend to every feature, and PHI must never be placed in fields or contexts (such as raw schema definitions) that fall outside the protected, covered channels**

C Whether the DevOps team has completed general security awareness training, which alone satisfies HIPAA requirements

D Whether the new feature is hosted in the same country as the original assistant, which is the only relevant HIPAA factor

CORRECT ANSWER **B**

WHY Enabling HIPAA readiness/BAA coverage for an account does not automatically extend to every feature that account can access — feature-level eligibility must be checked independently, and teams must avoid placing PHI anywhere outside the verified, covered processing path. A, C, and D all substitute an incomplete or irrelevant check for the actual feature-level verification required. --